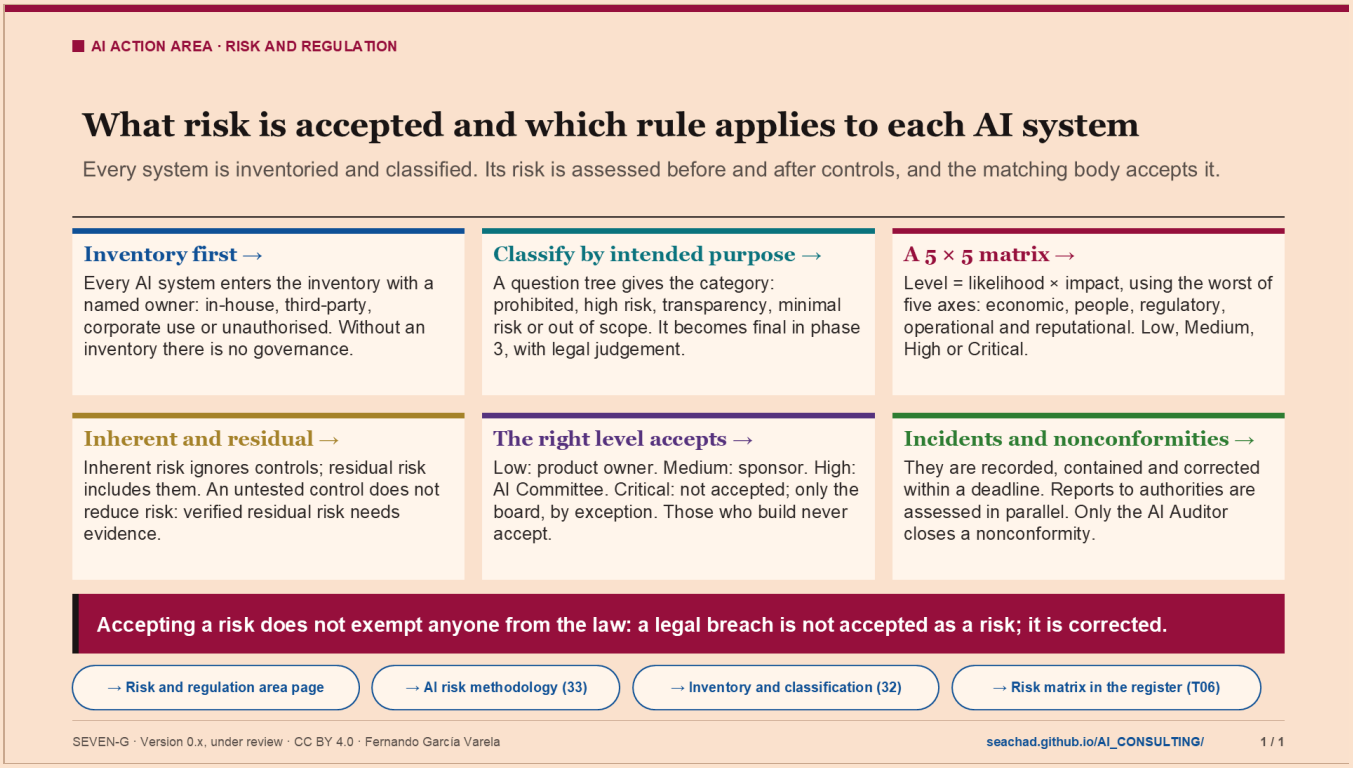


Notes

This slide summarises the Risk and regulation action area of SEVEN-G. It answers two questions the board needs to answer for every AI system: what risk the company accepts and which rule applies to it. The answer has six parts, read in order.

- Inventory first. All AI systems of four types of use are inventoried: in-house initiatives, third-party AI integrated in processes, corporate use of general-purpose tools and unauthorised use. Each system has a named owner, not a generic area. Why it matters: without knowing which systems exist, risks cannot be managed, obligations cannot be met and the board cannot be informed (document 32).
- Classify by intended purpose. A question tree, based on the EU AI Act, gives the system's category: prohibited, high risk, transparency obligations, minimal risk or out of scope. Classification follows the intended use, not the technology. It is provisional in phase 0 and final in phase 3, with qualified legal judgement. When in doubt, the most demanding category applies.
- A 5 × 5 matrix. The risk level is likelihood times impact, each from 1 to 5. Impact is the worst of five axes: economic, people and rights, regulatory, operational and reputational. It is not averaged. There are four levels: Low (1 to 4), Medium (5 to 9), High (10 to 15) and Critical (16 to 25).
- Inherent and residual. Inherent risk is the level without the initiative's specific controls. Residual risk is the level with controls: target at design time and verified when there is evidence that the controls work. An untested control does not reduce verified risk.
- The right level accepts. Each residual level is accepted by a different body. A Critical residual is not accepted; only by exception, by the board or its board committee. A Critical residual without that approval blocks the feasibility gate (G3) and the go-live gate (G5).
- Incidents and nonconformities. An AI incident is an event in which a system causes or may cause harm. A nonconformity is a failure to meet a mandatory requirement of the framework. Both are recorded, contained and corrected within a deadline.

An example with fictitious data from the site's example register: the customer service conversational assistant (IA-2025-002) is classified with transparency obligations, because people talk to an AI. Its risk that a prompt injection reveals another customer's data is Critical without controls (4 × 4 = 16) and Medium with tested controls (2 × 4 = 8). That is why the AI Sponsor accepts it, with clearance from the AI Risk Owner.

Important notice: SEVEN-G is not legal advice and does not guarantee compliance with any rule. Each organisation identifies the regulation that applies to it, including that of its sector, and verifies that it is in force with qualified advice (document 34).

Question for the classroom: in your organisation, who signs off the acceptance of a high risk in an AI system today? Is it the same person who builds it?

SOURCES AND LINKS

- **Risk and regulation area page** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/areas/riesgo.html
- **Document 33 · AI risk methodology** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/33_SEVEN-G_Metodologia_de_riesgos_de_IA.html
- **Document 32 · Inventory and regulatory classification** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/32_SEVEN-G_Inventario_y_clasificacion_regulatoria.html
- **Document 34 §1 · Scope and responsibility of the regulatory mapping** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/34_SEVEN-G_Mapeo_regulatorio.html#purpose-and-scope
- **Document 37 · Nonconformities and incidents** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/37_SEVEN-G_No_conformidades_e_incidentes.html
- **Regulation (EU) 2024/1689 (EU AI Act), EUR-Lex** https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng
- **AI risk methodology (33)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/33_SEVEN-G_Metodologia_de_riesgos_de_IA.html
- **Inventory and classification (32)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/html/en/32_SEVEN-G_Inventario_y_clasificacion_regulatoria.html
- **Risk matrix in the register (T06)** https://seachad.github.io/AI_CONSULTING/SEVEN-G/herramientas/T01_registro_iniciativas/registro.html

LEGAL NOTICE

Legal notice: a generic, free methodological aid provided "as is" for information purposes; it is not legal advice and has not been legally reviewed for any case. Each organisation adapts it and is responsible for its legal review and its regulatory compliance; it may not reflect recent regulatory changes. To the fullest extent permitted by law, the author accepts no liability whatsoever for the effects of its application. It does not grant certification of any kind. Details in document 93.

CC BY 4.0 (content) · MIT (code) · Fernando García Varela · seachad.github.io/AI_CONSULTING/